

Mapeo de Preguntas de la Encuesta a Requisitos Normativos y Pilares GCI

Nota: el mapeo es orientativo y se centra en marcos de referencia frecuentes (GCI, NIS2, ENS, RGPD/LOPD-GDD, ISO 27001, NIST CSF).

Nº Pregunta (Encuesta)	Pilar GCI	Tema principal	Marcos / Referencias relevantes
0.1-0.5 Datos generales	N/A (contexto)	Perfil organización	Segmentación analítica, enfoque ENISA pymes.[web:35]
1.1 Inventario normativo	Legal	Identificación de obligaciones legales	GCI Legal; NIS2 art. 20; ENS principios esenciales; ISO 27001 A.5
1.2 Análisis de brechas	Legal / Org	Evaluación de cumplimiento	GCI Legal/Org; NIS2 (gestión riesgos); ISO 27001 ciclo PDCA
1.3 Integra legal-ciber	Legal / Org	Gobernanza integrada	GCI Organizational; RGD; ENS organización
1.4 Evidencia digital	Legal / Technical	Cadena de custodia, forense	GCI Legal/Tech; Budapest; NIS2 respuesta incidentes
1.5 Cláusulas de ciber en contratos	Legal / Cooperation	Seguridad en la cadena de suministro	NIS2 (supply chain); ENS; ISO 27036
1.6 Formación jurídica	Legal / Capacity	Capacitación equipo legal	GCI Capacity; programas formativos nacionales.[web:38]
2.1 Inventario de activos	Technical	CMDB, activos críticos	NIST CSF (ID.AM); ISO 27001 A.5; ENS
2.2 Segmentación / Zero Trust	Technical	Arquitectura, control de acceso	GCI Technical; NIST Zero Trust; NIS2 requisitos técnicos
2.3 Inventario de nube	Technical / Org	Gobierno de servicios cloud	ENS; NIS2; ISO 27017; cláusulas de ciberseguridad en proveedores
2.4 Monitorización y SOC	Technical	Detección de incidentes	GCI Technical; NIS2; NIST CSF (DE); ISO 27001 A.8
2.5 Automatización (SOAR)	Technical	Respuesta orquestada	NIST CSF (RS); prácticas avanzadas SOC
2.6 Copias de seguridad	Technical	Resiliencia de datos	NIST CSF (PR.IP, PR.DS); ISO 27001 A.8; ENS
2.7 OT/ICS	Technical / Org	Seguridad industrial	NIS2 sectores críticos; IEC 62443; GCI Technical

2.8 Gobernanza de IA	Technical / Org	Uso seguro de IA	Buenas prácticas emergentes; referencias WEF, ENISA.[web:40] [web:41]
3.1 Estrategia de ciber	Organizational	Alineación con negocio	GCI Organizational; NIS2; ENS; NIST CSF (Governance)
3.2 Rol del CISO	Organizational	Responsabilidades, reporting	GCI Organizational; mejores prácticas de gobierno corporativo
3.3 Reporte al consejo	Organizational	Supervisión de alto nivel	NIS2 (gobernanza); principios de “digital operational resilience”
3.4 Gestión de riesgos	Organizational	Integración ciber-riesgos	NIS2; ISO 27005; NIST RMF; ENS
3.5 BCP/DRP	Organizational	Continuidad de negocio	NIS2; ISO 22301; NIST CSF (RS.RP, RC)
3.6 Gestión de incidentes	Organizational	Proceso formal	GCI Organizational; NIS2; NIST CSF (RS)
4.1 Formación empleados	Capacity	Concienciación y formación	GCI Capacity; ENISA campañas; ISO 27001 A.6
4.2 Simulacros de phishing	Capacity / Technical	Ingeniería social	Buenas prácticas industriales; NIST CSF (PR.AT)
4.3 Formación directivos	Capacity / Organizational	Ciber en el consejo	NIS2 responsabilidad directiva; GCI Organizational/Capacity
4.4 Dimensionamiento equipo	Capacity	Recursos humanos especializados	GCI Capacity; políticas de talento en ciberseguridad. [web:39][web:41]
4.5 Subcontratación servicios	Organizational	Modelo de sourcing	NIS2 (supply chain); ISO 27036; GCI Cooperation
4.6 Plan de desarrollo profesional	Capacity	Certificaciones y carrera	GCI Capacity; frameworks de competencias (ENISA, etc.)[web:35]
5.1 Redes y foros	Cooperation	Participación sectorial	GCI Cooperation; foros nacionales/UE
5.2 Intercambio de información	Cooperation	Sharing de amenazas	NIS2; CSIRT networks; GCI Cooperation

5.3 Ejercicios conjuntos	Cooperation / Org	Ejercicios multi-actor	GCI Cooperation; ENISA ejercicios “Cyber Europe”
5.4 Cooperación interna	Organizational	Trabajo transversal	GCI Organizational; buenas prácticas de gobierno
6.1–6.4 Inversión y ROI	Org / Capacity	Presupuesto, valor, percepción	Referencias industriales (PwC, Deloitte) a presupuestos y preparación.[web:34] [web:41]

Este mapeo permite:

- Conectar cada respuesta con obligaciones y buenas prácticas reconocidas.
- Generar informes alineados con el lenguaje de reguladores y auditores.
- Alimentar cuadros de mando nacionales o sectoriales congruentes con el espíritu del GCI.[web:28] [web:33]